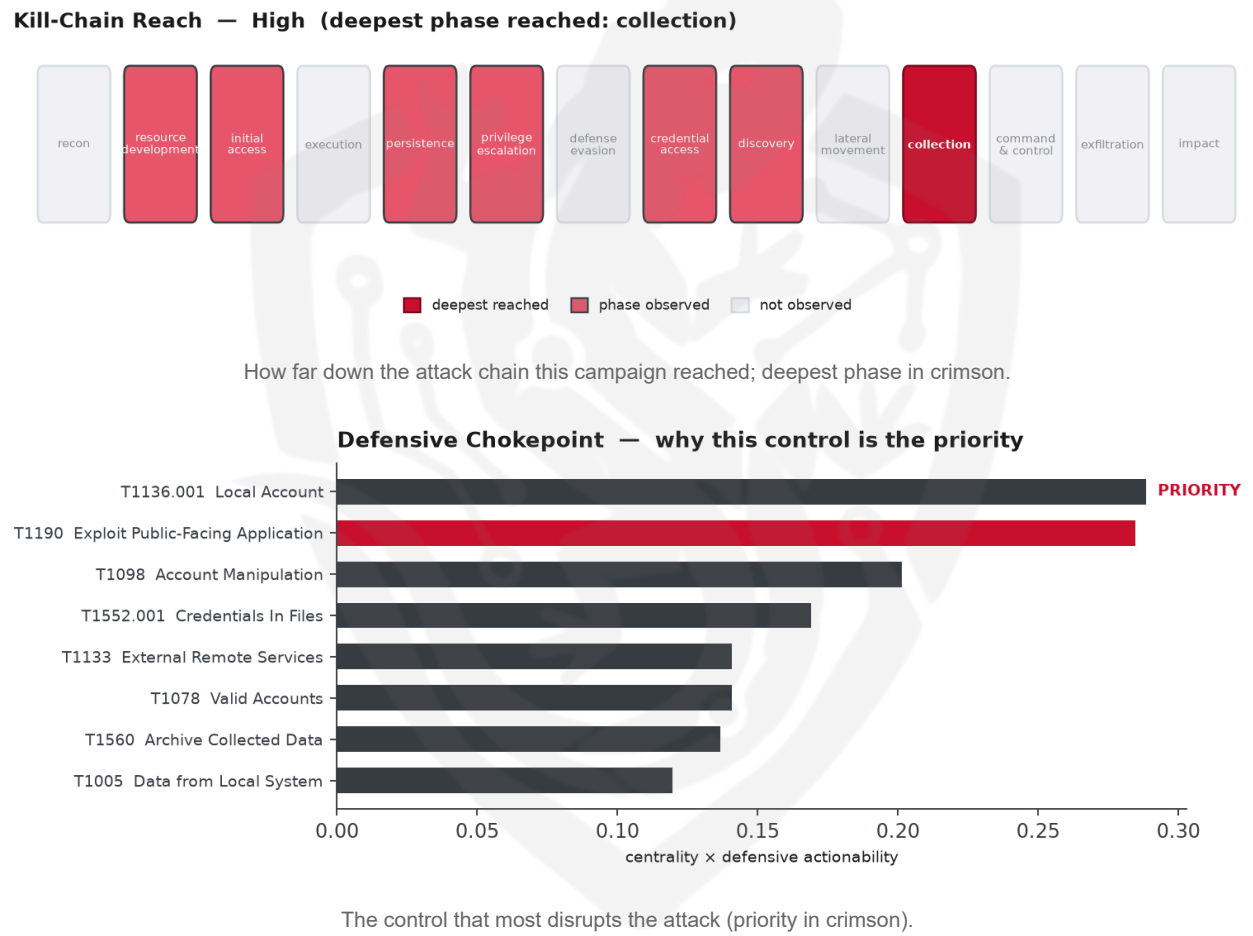


THREAT REPORT: PHILIPPINE GOVERNMENT AND NAVAL CONTRACTOR TARGETED WITH SLIVER, METASPLOIT AND METTLE EXPLOITS

Visual Summary



Summary

An observed cluster of activity leveraged the public-facing vulnerability CVE-2023-49105 to compromise systems in the Philippines’ government, defense and energy sectors. The attackers employed the Sliver, Metasploit and Mettle toolsets to gain initial access, move laterally, and collect a broad range of data. Victims included a national nuclear agency and a naval contractor. Priority should be given to patching the vulnerable public-facing applications and applying virtual WAF protections as outlined in the source’s recommended control.

Threat Overview

The source does not attribute the activity to a specific group, describing the adversary only as an unidentified threat actor. The campaign used the Sliver, Metasploit and Mettle malware families. Exploitation centered on CVE-2023-49105 (and references to CVE-2024-28000) to gain footholds in targeted Philippine government, defense and energy organizations.

Attack Chain and Priority Control

The observed techniques follow a typical intrusion flow:

1. **T1190 Exploit Public-Facing Application** – exploitation of CVE-2023-49105 to achieve initial compromise.
2. T1110.001 Password Guessing – brute-force attempts on exposed services.
3. T1133 External Remote Services – use of compromised remote access points.
4. T1087 Account Discovery and T1083 File and Directory Discovery – mapping user accounts and system files.
5. T1005 Data from Local System and T1074.001 Local Data Staging – gathering and staging data on the host.
6. T1560 Archive Collected Data – compressing harvested information.
7. T1114 Email Collection, T1039 Data from Network Shared Drive, T1213 Data from Information Repositories – extracting communications and shared resources.
8. T1003 OS Credential Dumping and T1552.001 Credentials In Files – harvesting additional credentials.
9. T1587.001 Malware and T1587.004 Exploits – deploying additional payloads (Sliver, Metasploit, Mettle).

Priority technique: T1190 Exploit Public-Facing Application.

Priority control (verbatim): *Patch the affected public-facing CVE immediately; apply a WAF virtual patch; restrict management interfaces to VPN-only. In parallel, patch CVE-2023-49105 on all affected systems.*

Infrastructure and Corroboration

Third-party enrichment shows the malicious infrastructure is hosted by CGI Global Limited, as identified by its ASN. Abuse.ch corroborates the presence of additional malware families, specifically IClickFix and an unnamed “Unknown malware.” No high-confidence AbuseIPDB flags were observed for the indicators.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1110.001 Password Guessing
- T1003 OS Credential Dumping
- T1133 External Remote Services
- T1114 Email Collection

- T1074.001 Local Data Staging
- T1587.001 Malware
- T1005 Data from Local System
- T1190 Exploit Public-Facing Application
- T1608.002 Upload Tool
- T1560 Archive Collected Data
- T1136.001 Local Account
- T1087 Account Discovery
- T1583.003 Virtual Private Server
- T1083 File and Directory Discovery
- T1552.001 Credentials In Files
- T1098 Account Manipulation
- T1039 Data from Network Shared Drive
- T1078 Valid Accounts
- T1587.004 Exploits
- T1213 Data from Information Repositories

Analytical Scores

- Priority technique (graph chokepoint): T1190 Exploit Public-Facing Application (centrality 0.3254).
- Operational risk: High (score 0.604, reaches collection).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.3825; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Dragonfly	0.3825
FIN13	0.3778
VOID MANTICORE	0.3714
Fox Kitten	0.3666
APT5	0.3267

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

- Malware families corroborated by abuse.ch: IClickFix, Unknown malware.
- Note: enrichment raises the severity signal (an IOC at or above 80% AbuseIPDB confidence, or a confirmed malware-family hit). This is context, not a change to the source assessment.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	31[.]58[.]209[.]241	AbuseIPDB 0% (NL) · AS56971 CGI Global Limited
Domain	fine-work-team[.]com	Unknown malware · malware_download
Domain	timelevel12[.]com	IClickFix · malware_download
Domain	snake[.]zooparkko[.]com	Unknown malware
URL	hxxp://timelevel12[.]com/big	
URL	hxxp://fine-work-team[.]com/6272	
URL	hxxp://snake[.]zooparkko[.]com/collect	
URL	hxxp://snake[.]zooparkko[.]com/collect[.]	
URL	hxxp://timelevel12[.]com/big[.]	
Hash	10df3451915ea35bcb17efe121415f24182680e2d07fc09df07ee695072104c1	
Hash	7447d0d0c34779d4c519823b39bf6ddc16d2b34a226b82ee69da6f5b4a77ad82	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1190 Exploit Public-Facing Application (initial-access)
- **Observed here:** T1190 Exploit Public-Facing Application was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the

execution stage they must still reach.

- **Projected pivot:** T1047 Windows Management Instrumentation (execution)
- **Basis:** of the 22+ groups that use Exploit Public-Facing Application, this pairing runs 2.0x above base rate, a disproportionately-coupled move rather than the obvious one.

With T1190 Exploit Public-Facing Application blocked, the threat actor could preserve the same objective by pivoting to T1047 Windows Management Instrumentation, a technique disproportionately paired with it across tracked groups. Defensive countermeasure: Monitor wmiprvse.exe child-process creation; restrict remote WMI (DCOM) at the host firewall; enable WMI-Activity operational logging.

Also plausible (same tactic): T1053 Scheduled Task/Job (n=23, lift 1.5), T1059 Command and Scripting Interpreter (n=38, lift 1.2)

Detection and hardening for the pivot (T1047 Windows Management Instrumentation)

- **Telemetry:** Sysmon (WMI events); Microsoft-Windows-WMI-Activity/Operational
- **Detect:**
 - Sysmon 19/20/21 (WMI event filter/consumer/binding) for persistence
 - wmic.exe / WmiPrvSE.exe spawning shells; remote WMI process creation
 - WMI-Activity/Operational operations from unusual users/hosts
- **Harden:**
 - Restrict WMI remote access; monitor permanent WMI subscriptions
 - Least-privilege; segment management protocols
- **MITRE:** M1040 Behavior Prevention, M1038 Execution Prevention, M1026 Privileged Account Management · DS0009 Process, DS0005 WMI, DS0017 Command